Gestão de Credenciais e Cofres de Segredos

> Identity and Access Management (IAM) para Workloads e Identidades Não Humanas.

[ARQUITETURA, CICLO DE VIDA E DEFESA EM PROFUNDIDADE]



Gemini Notebook

Fundamentos Conceituais

Identidade:	Quem/o que atua (Ex: svc-pedidos-prod). Não é senha.
Referência:	Onde buscar (Ex: prod/pedidos/banco). Não é o valor.
Segredo:	O valor confidencial (Ex: VALOR_FICTICIO).
Permissão:	A regra no destino (Ex: Ler banco). O cofre não substitui isso.

ATENÇÃO: Base64 é codificação, não criptografia. JWT assinado protege integridade, mas não oculta o conteúdo.

Matriz de Credenciais

		CUIDADO
Senha	Valor compartilhado.	Não reutilizar entre ambientes.
Token	Artefato com finalidade/prazo (Bearer).	Verificar escopo e validade.
Chave de API	Associa cliente/projeto.	Pode gerar custos; não presumir escopo restrito.
Chave Privada	Prova posse/assina.	Nunca confundir com chave pública. Evite exportação.
Certificado	Vincula chave pública à identidade.	Arquivos .pfx/.p12 embutem a chave privada (exige proteção).

Gemini Notebook

A Superfície de Exposição: Onde os Segredos Escapam



1. Código e Git

Histórico, branches, revisão.

Correção: Guardar apenas a referência. Detectar antes do commit. Se vazar, revogar no destino. (.gitignore não apaga histórico).



2. Arquivo .env

Enviado via chat ou pastas públicas.

Correção: Não versionar. Controlar distribuição estritamente.



3. Logs e Traces

Exceções completas ou cabeçalhos.

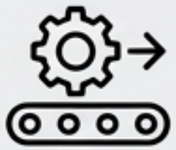
Correção: Registrar apenas campos permitidos. Filtrar observabilidade.



4. Imagens de Container

COPY, ENV, ARG e cache de camadas.

Correção: Injetar em runtime ou usar mecanismos de secret mount no build.



5. Pipeline CI/CD

Jobs maliciosos, runners, debug.

Correção: Limitar jobs. Separar identidade de publicação da identidade de execução.



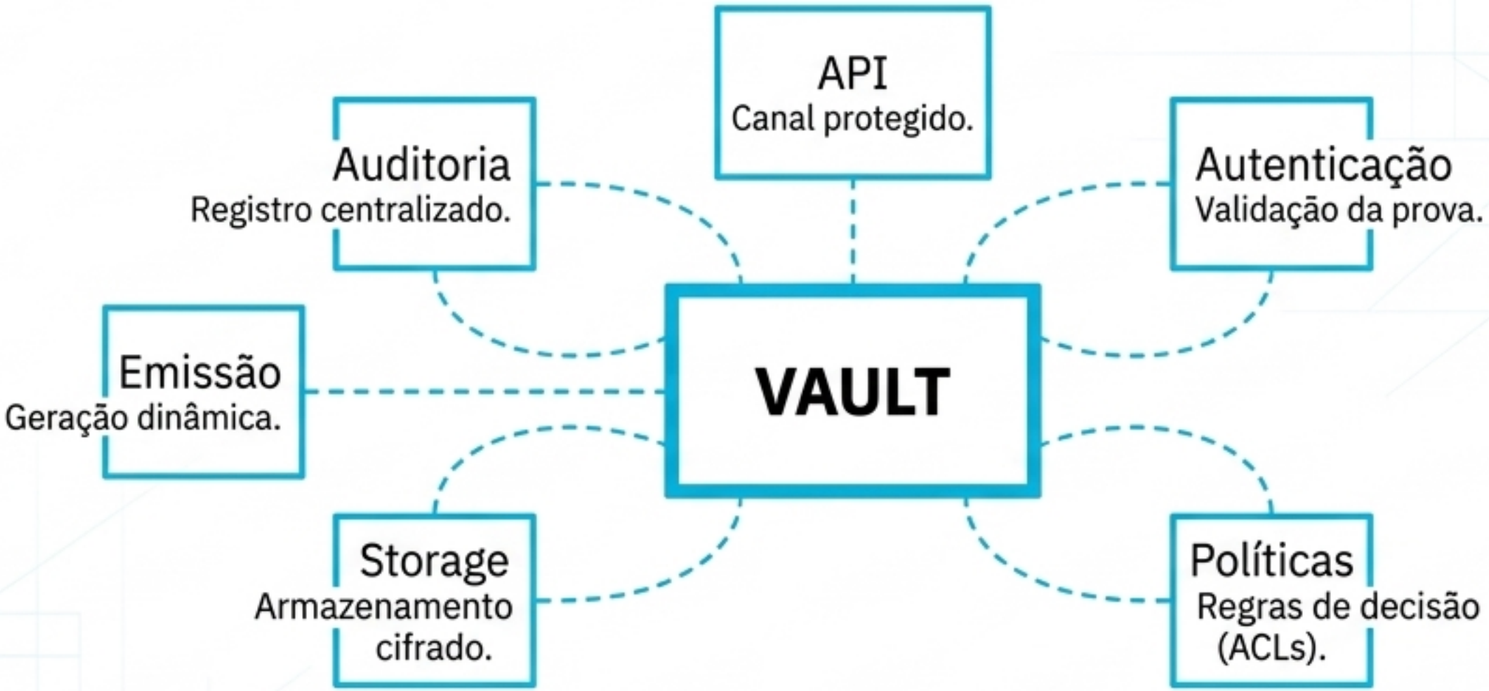
6. Tickets e Anexos

Capturas de tela, planilhas, suporte.

Correção: Usar IDs administrativos sem expor o valor real.

Gemini Notebook

Arquitetura: O Papel do Vault



Critério	Cofre Pessoal	Cofre Corporativo (Workloads)
Autenticação	Conta humana / Senha Mestra	Identidade de máquina / Federação
Entrega	Preenchimento no navegador	API, agente, automação
Ciclo de Vida	Uso estático humano	Versionamento, rotação coordenada, emissão temporária

Gemini Notebook

Camadas de Proteção Criptográfica

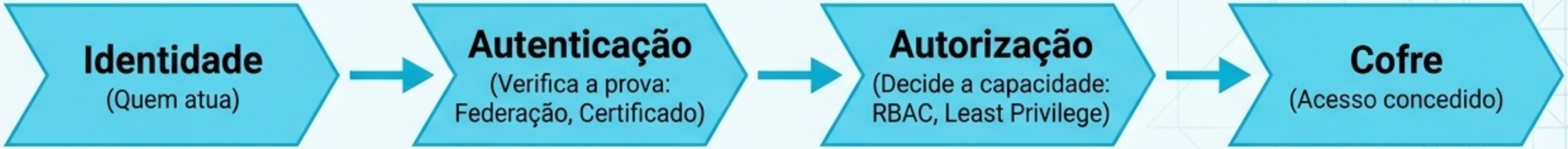
TLS (Em Trânsito)	**Protege:** Comunicação e verifica servidor.	**Limite:** Não impede que um cliente imprima o valor recebido no log.
Criptografia em Repouso	**Protege:** Discos, volumes e backups.	**Limite:** Não corrige permissão falha na API que autorize a leitura.
KMS (Envelope Encryption)	**Protege:** Gestão centralizada de chaves.	**Limite:** Não equivale a gerir o ciclo de vida da senha do banco.
HSM (Hardware Security Module)	**Protege:** Operações criptográficas em hardware.	**Limite:** Não dispensa administração correta e políticas lógicas.



Trocar a chave do KMS do cofre não troca a senha do banco de dados. O segredo pode existir em claro na memória do consumidor após a leitura.

Gemini Notebook

Autenticação e Autorização de Workloads

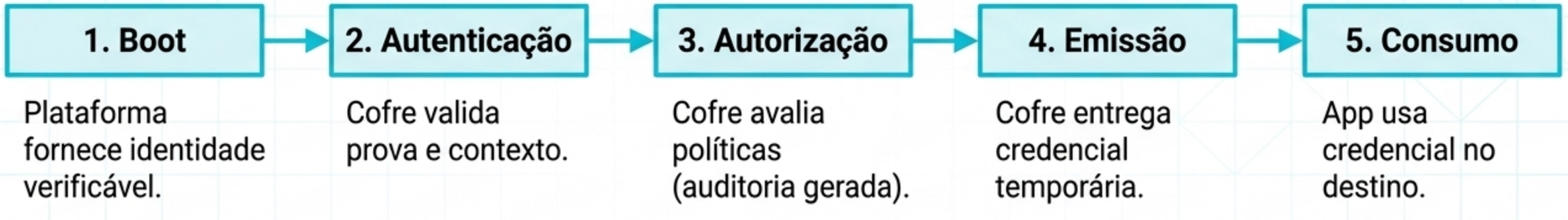


Exemplo de Limites de Privilégio Mínimo (RBAC)

Identidade (Workload)	Ação Permitida	Limite Inegociável
API de Pedidos (PROD)	Obter credencial do banco de pedidos.	Proibido ler segredos de outras APIs ou alterar políticas.
Job CI/CD de Publicação	Publicar nova versão.	Não tem acesso de leitura às senhas de banco em execução.
Automação de Rotação	Atualizar segredo específico no cofre e destino.	Execução estritamente auditada; sem poderes globais.

Gemini Notebook

Fluxo Seguro e Confiança Inicial (Bootstrap)



→ (O cofre não intermedeia o tráfego de negócio, apenas entrega a chave).

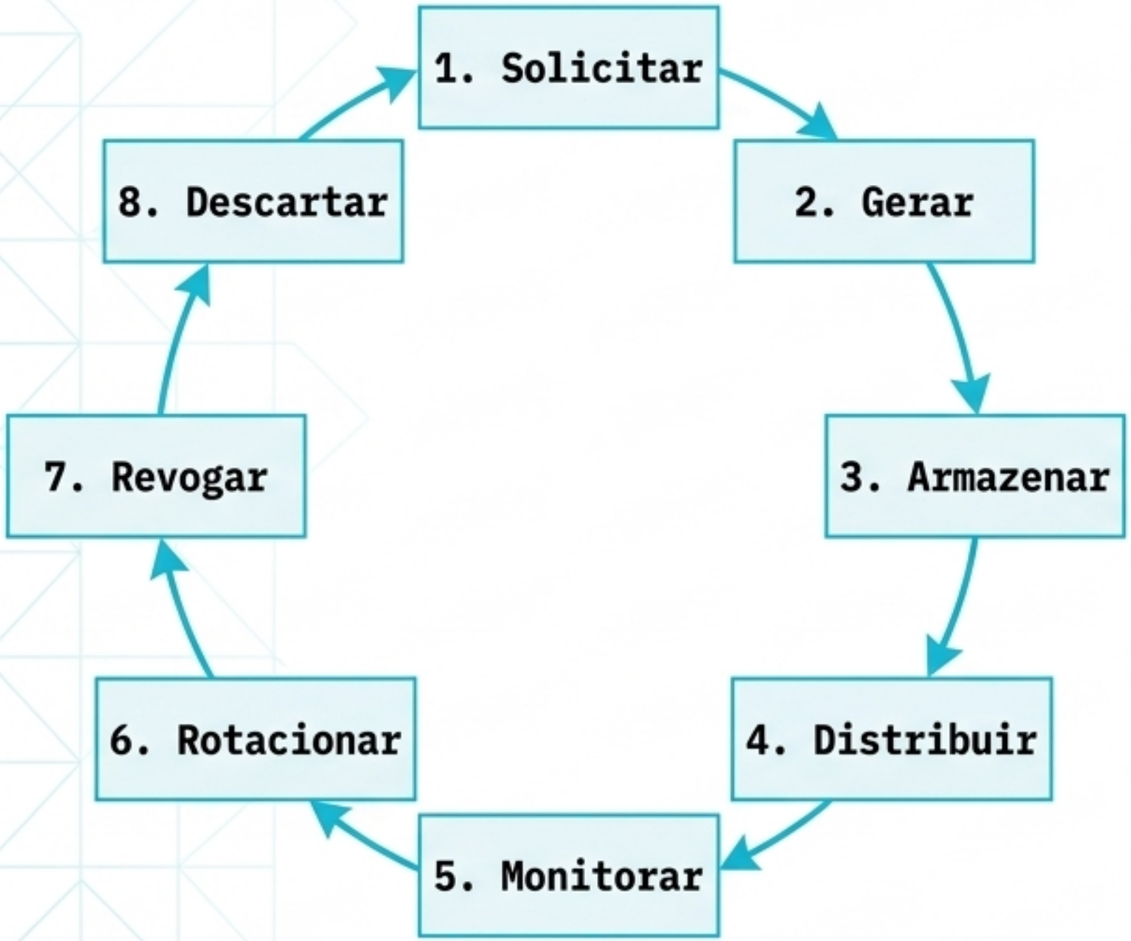
O Problema do Bootstrap

O que é: O estabelecimento da primeira confiança. De onde vem a primeira prova para abrir o cofre?

Regra de Ouro: Não fixe uma senha no código para abrir o cofre. Usar identidades gerenciadas pela plataforma (ex: `IAM roles`, `OIDC`) para provar quem o workload é.

Gemini Notebook

O Ciclo de Vida do Segredo



Evidências Exigidas (Sem expor o valor)	
Phase	**Evidence**
1. Solicitar	Justificativa registrada, responsável e duração.
2. Gerar	ID da transação, emissor e data.
3. Armazenar	Referência no cofre, versão e metadados.
4. Distribuir	Evento de acesso logado e teste de permissão.
5. Monitorar	Alertas de uso anômalo.
6. Rotacionar	Registro de teste e próxima revisão.
7. Revogar	Teste de recusa no destino e fim de sessões.
8. Descartar	Aprovação rastreável e remoção final.

REGRA ESTRUTURAL: O inventário rastreia referências e dependências, nunca o valor.

Gemini Notebook

Dinâmica Operacional: Desambiguação de Termos

Conceito	**Significado Exato**	**Não confundir com...**
Versionamento	Guardar histórico do texto no cofre.	Invalidar automaticamente o valor antigo no destino.
Rotação	Substituir credencial no cofre + destino + coordenar.	Apenas colar um texto novo no vault.
Expiração	Fim da validade ditada pelo prazo do sistema.	Uma etiqueta de data inútil que ninguém valida.
Revogação	Cancelamento ativo antes do prazo previsto.	Apagar do `vault` enquanto a credencial segue funcionando.
Renovação	Estender a concessão de um `lease` válido.	Necessariamente emitir um valor novo.

Gemini Notebook

Tipologia Tática: Estáticos, Dinâmicos e Temporários

Estático Versionado
(Ex: Chave de API Externa)

Permanece igual até automação substituí-lo. Rotação exige coordenação manual ou pipeline específico com a API.

Dinâmico
(Ex: Usuário de DB gerado na hora)

Excelente atribuição. Cofre precisa de privilégios de administrador no destino para criar a credencial (proteger este acesso central).

Temporário
(Ex: Token de 15 minutos)

Reduz janela de exposição drasticamente. Se roubado durante a validade, ainda pode ser abusado temporariamente.

Mecânicas de TTL e Leases

Lease: A concessão temporária acompanhada pelo vault.

Alerta de Risco: Se um atacante controla o workload comprometido, ele pode simplesmente solicitar ***novos*** tokens temporários continuamente. A contenção deve bloquear a identidade no vault e o acesso no destino.

Gemini Notebook

Padrões de Consumo Seguro por Aplicações

1. API / SDK (Acesso Direto)

Cliente consulta cofre em runtime. (Padrão mais recomendado).

Cuidados: Tratar falhas de rede, gerir cache, impedir que exceções imprimam a resposta em logs.

2. Agente / Sidecar

Processo auxiliar baixa o segredo para a app.

Cuidados: Proteger o canal/arquivo de entrega local; garantir que a app reconheça as recargas.

3. Arquivo Montado (Volume)

Segredo aparece em caminho restrito temporário.

Cuidados: Permissões OS mínimas (chmod), não incluir em backups, gerir remoção.

4. Variável de Ambiente (ENV)

Plataforma injeta no processo.

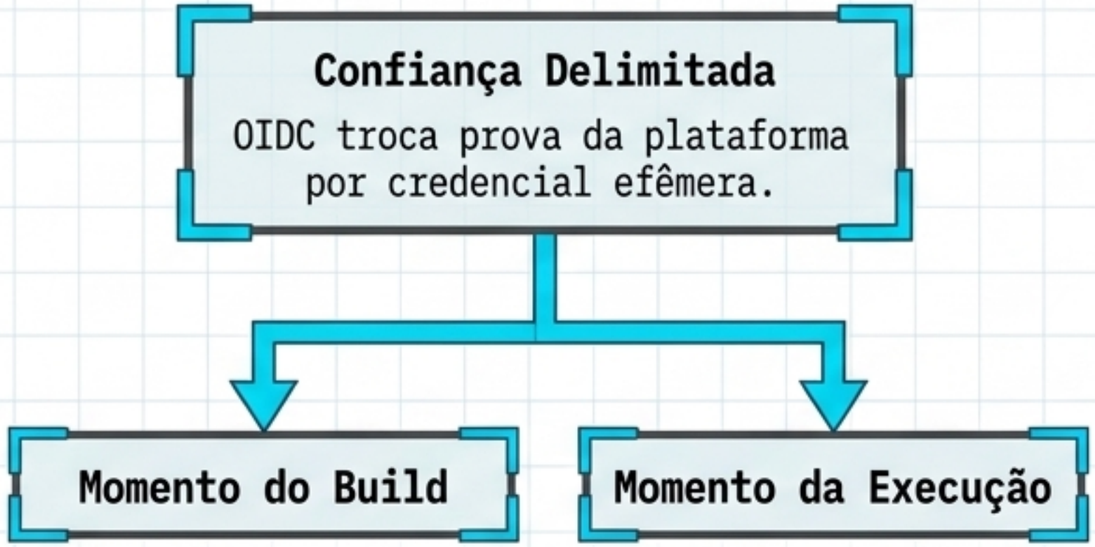
Cuidados: Risco altíssimo de exposição em logs, traces e child processes. **Aviso:** .env não é cofre.

REGRA DE CACHE: Se usar cache para tolerância a falhas, limite o prazo.
Não assuma que a cópia local some apenas porque a origem foi revogada.

Gemini Notebook

CI/CD, Containers e Serviços Modernos

Segregação de Contexto (Pipeline)



Usar secret mounts efêmeros (BuildKit). Nunca usar ENV, ARG ou COPY.

Excluir arquivo em camada posterior NÃO remove do histórico.

Apenas a identidade de runtime obtém segredo no vault.

Pipelines não tocam em credenciais de runtime de produção.

A Realidade do Kubernetes

Native Kubernetes Secret

```
data:
  password: cGFzc3dvcmQxMjM=
```

O K8s codifica em Base64 (texto perfeitamente legível). Isso não é criptografia por padrão.

- Exige RBAC rígido sobre quem pode criar pods que montam esses secrets.
- Exige criptografia em repouso configurada no etcd.

Gemini Notebook

Monitoramento, Auditoria e Continuidade

Sinais de Auditoria

O que logar: Identidade, Referência, Ação, Origem, Resultado. (Nunca logar o valor).

Sinal -> Ação		
Sinal: Muitas leituras incomuns.	→	**Ação:** Comparar com deploys; suspeitar de coleta indevida.
Sinal: Recusas cruzadas (Ex: Dev chamando Prod).	→	**Ação:** Investigar origem; nunca ampliar acesso automaticamente.
Sinal: Falha repetida de renovação.	→	**Ação:** Acionar **continuidade;** verificar destino.

Sobrevivendo à Indisponibilidade

Cache Controlado
Usar apenas dentro da validade.

↓

Resiliência
Parar operações dependentes; manter funções isoladas vivas.

↓

Proibição Absoluta
Nunca criar fallback com senha fixa no código da aplicação.

↓

Acesso de Emergência (Break-glass)
Acesso humano de resgate: exige escopo restrito, justificativa e auditoria rigorosa.

Gemini Notebook

Matriz de Riscos Residuais e Controles

Mercado: Vault, AWS Secrets, Azure KV, Google SM. (A ferramenta não encerra o risco).

Cenário de Risco	Controle Aplicado	Verificação	Risco Residual
Credencial exposta no Git.	Prevenção de commit + Cofre.	Teste de recusa no destino.	Clones locais e tokens derivados antigos ainda podem existir.
Permissão excessiva (Ler tudo).	Least Privilege + Separação (Dev/Prod).	Testes explícitos de acesso negado.	Se o workload for invadido, o acesso continua válido para aquela máquina.
Rotação Incompleta.	Inventário de consumidores + invalidação.	Credencial antiga falha 100%.	Sessões longas abertas no banco de dados podem sobreviver à troca de senha.

Gemini Notebook

Resposta a Incidentes e Checklist Definitivo

Fluxo de Resposta a Vazamentos



1. Identificar
(Delimitar identidade e permissões. Não testar em sites públicos).

2. Conter
(Revogar no destino; bloquear workload no cofre).

3. Preservar
(Salvar logs e IDs sob sigilo).

4. Investigar
(Falta de log não prova ausência de abuso).

5. Recuperar
(Emitir credencial nova, não reusar).

6. Aprender
(Fechar lacunas, ajustar alertas).

Checklist de Boas Práticas Essenciais

Identidade & Bootstrap
Workloads isolados; ausência total de senhas fixas no código para abrir o cofre.

Políticas & Isolamento
Escopo mínimo enforceado; separação rigorosa e intransponível entre Dev/Homologação/Prod.

Superfície de Exposição
Zero strings confidenciais enviadas para Git, imagens de container, outputs ou logs.

Ciclo de Vida
Rotação atinge ativamente o destino; invalidação é rigorosamente testada; dependências mapeadas.

Gemini Notebook